DOMINICAN DIGITAL ID · PROOF OF CÉDULA

Test key in production. Nonexistent root of trust.

URGENT ACTION. Every production cédula we examined carries a signature backing its anti-cloning guarantee that was made with a vendor test key, RSA-1024, and the JCE's root of trust does not exist online. More than 4 million cédulas have already been delivered, out of 8.7 million enabled. These flaws must be fixed now, and together.

Scope: production cédulas issued from early 2026 through September 2026, examined with their holders' permission, using public information and documented ICAO/ISO protocols. No citizen data. The Central Electoral Board (JCE) was informed of the most serious findings before this publication.

FINDINGS

FINDING 1 ■ CONFIRMED DEFECT — **RSA-1024 development key in production**

What fails. EF.CardSecurity, the object that underpins the guarantee that the chip is not a clone, is signed by an RSA-1024 Document Signer of development provenance (**cryptovision/development**) on **all** the production cards examined. RSA-1024 is obsolete and within reach of an adversary with state-level resources. A development key, moreover, may ship in the vendor's SDK or sample material: then it is practically public. **Audit failure:** a test key reached production undetected.

What to do now. Determine immediately whether the private key exists in vendor material and **treat it as compromised until proven otherwise.** Replace the signer with a production signer exclusive to the JCE. Investigate how a development key reached production.

FINDING 2 ■ CONFIRMED TRUST GAP — **The JCE's root of trust does not exist online**

What fails. The published CSCA anchor, https://ca.jce.gob.do/csca, returns **NXDOMAIN**: the name does not resolve. The revocation list is on the same nonexistent host. A verifier cannot anchor the identity signer's chain (EF.SOD) or receive a revocation. The signature is intact; what is missing is a reachable, pinned root that proves who signed.

What to do now. Publish the CSCA and the CRL at a reachable location, pin the anchor in all verifiers, and require them to **fail closed** on a signer they cannot anchor.

HOW THEY COMBINE: CLONED CARDS ACCEPTED

Possible threat model, built from the two findings; it was not run against any real system. Anyone holding a cédula, even for a moment, could read its data using the CAN printed on it. If they obtained the Finding 1 key, they could sign a replacement EF.CardSecurity and build a clone that **passes Chip Authentication**, the check that exists precisely to detect clones. Given Finding 2, verifiers that fetch the root at runtime could accept an unanchored signer. **In this model, any application that trusts the development certificate, or accepts a signer it cannot anchor, could be fooled by a cloned or edited card.**

POSSIBLE ATTACKS

Models with explicit preconditions; none was run against real systems.

	Attack	Requires
A	**Clone that passes Chip Authentication.**	The development signer's key (from vendor material or by factoring RSA-1024), a copy of the readable data, and a verifier that accepts that signer.
B	**Fail-open acceptance.** A verifier that cannot obtain the root accepts an unanchored signer, even a forged or self-signed one.	Only a verifier written that way. No card is compromised.
C	**Downstream fraud:** KYC, customer onboarding and kiosks that accept a fabricated security object.	That the system skips full passive authentication with anchoring.
D	**Signer impossible to revoke.** If the key leaks, there is no effective way to warn verifiers. The certificate is valid until 2079.	Leaked or broken key.
E	**Offline, undetectable key compromise.** Using the key requires touching no JCE card or system: it leaves no trace.	Only the key and a verifier that accepts the signer.

URGENT ACTIONS

1. **Now:** confirm whether the development private key is in the vendor's hands or in its SDK, and treat it as compromised in the meantime.
2. **Now:** restore the CSCA and CRL at a reachable location and pin the anchor in all verifiers. Fixing the key and publishing the CSCA **must be done together**.
3. **Now:** fix the personalization of cards not yet issued; establish whether those already issued can be updated; reissue only what cannot be fixed. Do not wait for the audit for this.
4. **Verifiers:** audit those that consume the card (JCE app, third-party readers, KYC, kiosks): fail closed, pinned anchor, rejection of the development signer.
5. **Audit:** commission a full, independent cryptographic audit, led by qualified cryptographers independent of the vendor and backed by the JCE, with access to key records, card profile, personalization software and witnessed readings of cards from different batches. Decide on general reissuance based on its results.

LIMITS

We found all of this from the outside, using public information: without access to JCE records, key ceremonies, signing hardware or vendor documentation. **We cannot rule out other flaws.** Tests on the card that did not succeed (writing data via CAN/PACE, altering the MAC or downgrading Secure Messaging, forging EF.SOD with the RSA-1024 key) describe what we tried and are not a guarantee. It does not cover issuer-credential paths or PIN brute force. This recommendation is not conditioned on any engagement of FACTOR Inc., which offers cryptographic audit services (declared commercial interest).

FACTOR Inc. · team@projectfactor.io · projectfactor.io · github.com/ProjectFactor/auditoria_criptografica

ANNEX: RSA-1024 CERTIFICATE DATA SHEET

Data of the Document Signer certificate that signs EF.CardSecurity on the production cédulas examined.

Field	Value
IDENTIFICATION	
Role	Document Signer (DS) of EF.CardSecurity
Version	3 (0x2)
Serial number	`70:01:22:04:88:CD:EF:EA:33:B2:6B:05:9A:28:63:7C`
Subject	`C=DE, O=cryptovision, OU=development, CN=DS`
Issuer	`C=DE, O=cryptovision, OU=development, CN=CSCA`
Valid from	2019-12-31 23:00:00 UTC
Valid until	2079-12-31 23:00:00 UTC (60 years)
PUBLIC KEY	
Algorithm	rsaEncryption
Key size	1024 bits (309 decimal digits)
Public exponent	65537 (0x10001)
Modulus (hex)	`a1c50ddf96ca191dc25bdc36dfebc9d0d92119bf29715715188a015693e08593 b5e3dc1baf0d514520 f78a6288786247651ead3e3888de1e8883942a4266e468 978e2184f3985a6b3975f599fc802dd7404e 7a4552f09fa5b6d456f3cca96ec5 1058c1f8429f370ff23e7888c2fb7cfd9fd3a320b1eb5f58fe019c 45807bbc69`
CERTIFICATE SIGNATURE	
Signature algorithm	sha256WithRSAEncryption
Signature length	2048 bits (256 bytes)
Signature value (hex)	`6c4a4dba4ff94923697e22c9145621317a29e4eb183bddfb4e5f17e2142a3f50ecf69ccab26b4fce4f2 926aeed9b9cde8d39a8861cefad1d6f7feb3cb4b02e1189bd2ea43a2dc59cb204094af960183936f355 2710f07dcd8a2560b88db021c3b00ace1b18b635eaefe1e07379120399bb10ce59e26e02a684bb92dbf dfb37d19370f26df40ce3b3285b6ffa083737df71e3729efacb544d2996564f2fafea74da34ab6d6768 e1ac242cfdcb219f2b724ce4842829a9b7cafb9779fdb64498d8698543858e54f81b6195e114ca47014 a71cbaba767e0d84e43cf9538a4e74982f378a7f7b4295f5d1870ad4d54d164f3dd24089a58cccf57a4 8ef0c754dd0320`
X.509 v3 EXTENSIONS	
Authority Key Identifier	`64:1F:97:8A:63:AE:1B:40:71:74:E9:6E:35:66:AF:34:7F:ED:3B:20`
Key Usage (critical)	Digital Signature
Subject Key Identifier	Absent
CRL Distribution Points	Absent (no revocation path)
Authority Information Access (OCSP)	Absent
FINGERPRINTS AND SIZE	
SHA-256 (DER)	`4E:B2:79:36:EE:EE:48:8C:84:09:04:4D:8D:B3:FF:22:21:01:55:44:3B:89:DB:7E:4B:21:AE:E 2:F9:57:04:E2`
SHA-1 (DER)	`9E:99:EF:6D:5D:8F:CE:53:37:12:53:99:B7:71:4B:F1:34:7A:90:DE`
DER size	719 bytes
USE AND PRESENCE ON THE CÉDULA	
Object it signs	EF.CardSecurity (1,225 bytes)
SHA-256 of the object	`09b130edd80f8cf20ac9ecce8bcc5f03dd59e7a03c3e61243e0a045c1bdde7bf`
Signed content	22 bytes: PACE declaration (id-PACE-ECDH-GM-AES-CBC-CMAC-256)
Provenance	development (cryptovision/development)
Present on	All production cards examined
Algorithm status	RSA-1024: obsolete